

BioDevOps: An Assurance Architecture for Bounded Agentic Evidence Assembly in Medical-Device Governance

First A. Author, Second B. Author, and Third C. Author

Abstract—Agentic artificial intelligence can accelerate evidence retrieval and synthesis in medical-device governance, but safeguards must separate automated recommendations from accountable release authorization. We present BioDevOps, an assurance architecture for bounded agentic evidence assembly. A typed *RiskReport* links a bounded agent to an evidence graph; Open Policy Agent enforces evidential and procedural requirements; the Shapes Constraint Language checks reports against curated clinical facts and can trigger one revision; and a modeled external interface represents human release authority. We evaluated it with Alloy and TLA+, conformance and mutation tests, and 2,000 attempted runs across ten open-weight models on synthetic, public post-market, model-scale, and cross-domain benchmarks. No counterexample to the specified autonomy, accountability, or evidence-mediation properties was found within the explored scopes. Of 2,000 attempts, 1,947 produced reports terminating as advisory packages or governed escalations; no terminated trace accepted a schema-invalid, unparseable, or state-illegal action. On 20 held-out public device reports, enforcement changed under-routing from 2/20 to 0/20 while over-routing reached 14/20. Across three models, 16 of 39 consistency-triggered revisions changed severity or recommendation, without necessarily resolving all non-conformities. Under the evaluated conditions, automated evidence assembly remained inspectable and distinct from the modeled authorization interface.

Index Terms—Agentic artificial intelligence, formal methods, healthcare governance, human oversight, medical device software, policy as code, trustworthy artificial intelligence.

I. INTRODUCTION

AGENTIC artificial intelligence can inspect records, retrieve artifacts, and synthesize validation recommendations. In medical-device validation, this makes the boundary between evidence production and release authority a first-order governance problem: trustworthy-healthcare frameworks require traceability, accountability, and human oversight [?], [?], [?], while device regulation requires validation, risk management, and controlled change [?], [?], [?]. Realizing autonomous, trustworthy, and human-centric agentic systems in healthcare therefore requires an architecture, not only a

capable model: one that makes agent autonomy, safety, and accountable human oversight structurally verifiable rather than aspirational. Such governance mechanisms can support future evaluation of agentic AI in clinical and home-care environments, where automated evidence work must remain auditable under regulatory, ethical, and privacy constraints.

Authority becomes ambiguous when advice is treated as a decision, cited material does not support its claim, or review lacks a record of the human decision. An assurance architecture must therefore separate advice from approval, preserve claim-to-evidence paths, and expose unresolved conditions before release.

The agent produces an advisory *RiskReport*; Open Policy Agent (OPA) checks evidential and procedural conditions and routes it for human review, while authorization remains with a modeled—not integrated—external service. An evidence graph links clinical events, artifacts, tests, obligations, and review actions. The Shapes Constraint Language (SHACL) provides post-hoc consistency analysis and a controlled one-revision path; Alloy/Temporal Logic of Actions (TLA+) models and conformance/mutation tests examine structural, temporal, and operational properties.

This paper makes three contributions:

- an evidence-to-authority architecture with formally checked invariants that assign recommendation and authorization to separate objects, actors, and controls;
- a bounded evidence-assembly agent and typed contract combining traceable trajectories, deterministic transitions, OPA enforcement, and SHACL analysis; and
- a multi-method evaluation spanning extended formal scopes, 2,000 attempted runs across ten models, field provenance, mutation-sensitive tests, public Manufacturer and User Facility Device Experience (MAUDE) reports, and cross-domain transfer, providing inspectable evidence for evaluating agentic-AI governance claims.

a) *Study scope.*: We evaluate reviewer decision rights, traceability, bounded agent behavior, and accountable routing against reproducible developer-authored governance references. Human reliance, clinical effectiveness, and authenticated production integration require separate evaluation.

A preliminary version of this work has been reported [?].

II. RELATED WORK

Trustworthy-AI frameworks call for traceability, accountability, oversight, fairness, usability, and robustness [?], [?],

Manuscript received XX Month 2026; revised XX Month 2026. This work received no external funding. (Corresponding author: First A. Author.)

The authors are with the Department, Institution, City, Country (e-mail: contact@institution.edu).

[?], [?]. Device guidance, the EU MDR, and ISO standards add validation, risk-management, change-control, and AI-management duties [?], [?], [?], [?], [?], [?], [?]; RegOps brings such controls into deployment pipelines [?]. We provide an executable counterpart: developer-authored OPA and SHACL controls motivated by ISO 14971 and GMLP. Preliminary BioDevOps work [?] separated evidence production from authorization; this article makes that boundary agent-specific, executable, formally checked, and empirically evaluated.

Agentic systems combine planning, retrieval, and tools [?], [?]; healthcare benchmarks probe them in simulated clinical and EHR tasks [?], [?], [?], while structural critiques emphasize accountable oversight [?]. Complementary JBHI work operationalizes trustworthy-AI guidance, diagnostic retrieval, and public-EHR benchmarking [?], [?], [?]; we govern the combination of retrieval, evidence assembly, generation, and intermediate decisions before release. Automation-bias and clinical studies show that workload, expertise, presentation, and incorrect advice affect reliance [?], [?], [?]. Reporting standards and organizational governance frameworks address adoption and oversight [?], [?], [?]; we complement them with an executable boundary where agent-produced evidence meets human authority.

Our neuro-symbolic design evaluates a fixed report contract against FHIR-shaped data, SNOMED CT mappings, and closed-world SHACL constraints [?], [?], [?], [?], [?]; bounded models and runtime tests examine authority and evidence properties [?]. Policy-as-code gates deployment artifacts [?], [?], [?], whereas agent guardrails constrain dialogue and tools [?], [?]. Neither checks generated evidential claims against curated clinical facts before human authorization in the setting targeted here. We compare direct generation, RAG, bounded-agent, and OPA-governed arms over identical scenarios (Section ??).

The preliminary two-page report [?] presented the state formula, admissibility condition, and qualitative insulin-pump scenario as a narrative specification, leaving tool encoding and evaluation as future work. This article adds Alloy and TLA+ /TLC models, executable OPA/SHACL controls, an agent-specific bounded runtime, mutation-sensitive tests, 2,000 attempted runs across ten models, public post-market evaluation, and cross-domain and paraphrase transfer.

III. FORMAL ARCHITECTURE MODEL

Telemetry, drift alerts, performance monitors, and post-market reports enter release decision-making only as reviewed, traceable evidence. The prototype implements report generation and routing; its external authorization interface is modeled—not integrated.

Building on BioDevOps [?], we represent governance as $P = (C, \Delta, R, V, E, G)$: changed components, change class, risk, validation path, evidence, and governance. Traceable *Artifact*, *Stage*, *RiskSignal*, and *Gate* structures connect claims to their producing change and stage. *Human Accountability* requires each *ApprovalRecord* to trace to an authorized human; the *AI Autonomy Constraint* permits evidence gathering and recommendation but excludes execution and deployment; and *Evidence-Mediated Governance* requires evidence

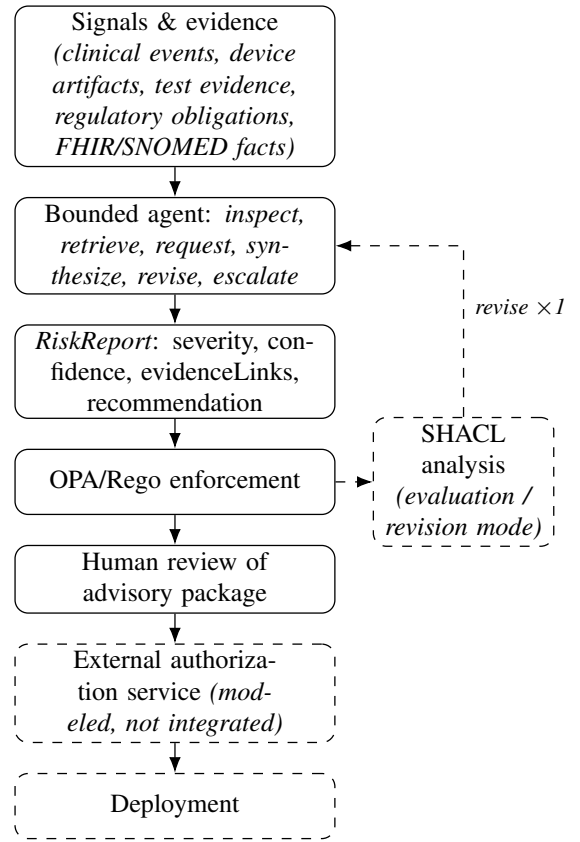


Fig. 1. Evidence-to-authority flow. OPA governs the advisory path to human review; evaluation-layer SHACL analysis can condition one bounded revision. Only the external authorization service can mediate deployment.

and authorized approval for gate transitions. Section ?? verifies these properties at extended bounds.

Pipeline stages emit validation or failure evidence; gates evaluate evidence, signatures, and policy. Riskier ML changes add drift, calibration, subgroup, simulation, or software-/hardware-in-the-loop evidence [?]. Agents request evidence-producing stages, whereas approval records originate at the external human gate.

IV. KNOWLEDGE-GUIDED AGENT

An evidence directed acyclic graph (DAG) connects clinical events, device artifacts, tests, obligations, and FHIR/SNOMED facts to the *RiskReport* and human review (Figure ??). The agent inspects signals, retrieves or requests artifacts, drafts a report, and revises once or escalates. Its actions are $\{inspect, retrieve, request, synthesize, revise, escalate\}$; validation, approval, and deployment are excluded. Actions record sources and outcomes, and allow-listed tools return evidence or failure records.

The model proposes actions, queries, or evidence requests; the runtime validates transitions, executes allow-listed tools, limits trajectories to six steps and one revision, applies OPA/SHACL, and escalates unresolved paths. JSON Lines (JSONL) traces record proposed and accepted actions, state hashes, retrieved identifiers, gaps, policy actions, configuration metadata, and termination. Thus, model-guided assembly remains under deterministic runtime control.

Report claims use typed evidence paths. The DAG records each artifact’s role, supported claim, provenance, contradictions, and missing dependencies, distinguishing authentic but irrelevant evidence from direct support. Citation validity therefore differs from evidential sufficiency and release authority.

The contract is $Input = \mathcal{P}(Artifact) \times \mathcal{P}(RiskSignal)$ and $Output = RiskReport = \langle severity, confidence, evidenceLinks, recommendation \rangle$. Recommendations range from *NoAction* to *EscalateImmediate*; none authorizes deployment. Claims link to signed evidence marked sufficient, weak, or absent, and report signatures record provenance rather than approval.

Determinism concerns enforcement, not generation: given a *RiskReport*, transition validation, trajectory bounds, OPA/SHACL application, and the external gate are deterministic (Section ??). Report content remains subject to decoding, serving, and model drift; the measured 72-hour same-digest variation is quantified under Threats to Validity. The in-loop path (Section ??) re-invokes the model, but the runtime still bounds the revision.

Two symbolic analyses operate at different stages. OPA/Rego enforces citation, escalation, field-action, and routing rules over the generated report. SHACL compares stored reports with curated FHIR-shaped facts and SNOMED CT mappings; the OWL 2 Web Ontology Language RL profile (OWL-RL) selects one-sided severity constraints. For example, confirmed ventricular fibrillation (SNOMED CT 71908006) makes *NoAction* or *Monitor* nonconformant.

OPA resolves identifiers and procedural conditions; SHACL compares typed assertions with fixed facts. Together they expose citation failures, missing evidence, severity undercalls, and graph contradictions. Assertion status—confirmed, suspected, negated, or mention-only—drives the continuous glucose monitoring (CGM) transfer experiment (Section ??).

Ordinal checks are one-sided: severity-floor, severity-4/death, and CGM confirmed-event rules flag under-triage, prioritizing missed escalation over extra review. A separate rule flags unsupported field-safety action to address unwarranted recall. Section ?? examines this asymmetry’s coverage gaps empirically.

The self-reported *confidence* field is routing metadata, not severity or a policy verdict. OPA combines it with citation, support, completeness, and escalation checks; authorization never depends on it.

OPA normalizes drafts by adding review, escalation, or missing-evidence actions; SHACL annotates the curated graph. The advisory package separates recommendation, sources, gaps, and policy actions, while release decisions remain external.

When measuring OPA-or-SHACL trigger yield, Section ?? disables universal review so that this routing invariant is not counted as check performance.

V. BOUNDED FORMAL VERIFICATION AND OPERATIONAL CONFORMANCE

The three properties retain passing results at larger bounds. Deployment requires complete, traceable, human-approved

evidence:

$$\begin{aligned} deploy(P) \Rightarrow & approved(G) \wedge complete(V, E) \\ & \wedge traceable(E, C, \Delta). \end{aligned} \quad (1)$$

The bounded temporal model checks a narrower risk-mediation condition over pending risks, $PendingRisk(P) \subseteq RiskSignal$:

$$\begin{aligned} \Box((\exists r \in PendingRisk(P) : \neg reviewed(r, E, G)) \\ \Rightarrow \neg authorized(P)), \end{aligned} \quad (2)$$

Under fair scheduling, pending risks eventually reach review, and new unreviewed risk revokes authorization. Alloy checks structure, TLA+/TLC temporal behavior, and Python enumeration provides a bounded cross-check. No encoded scope permits agent deployment, unauthorized approval, or authorization with unreviewed risk; operational tests exercise the corresponding report and routing controls.

The bounded checks verify $approved(G)$, $reviewed(r, E, G)$, and $authorized(P)$ against the variables the models track: $authorized(P)$ is a global Boolean, set by a *GrantAuthorization* transition exactly when every pending risk signal is reviewed; $reviewed(r, E, G)$ is a per-signal Boolean toggled by a *ReviewRisk* transition, treating review as an atomic action rather than separately modeling E and G ; and the Alloy autonomy model checks $approved(G)$ as gate-set membership, granting execution capability only when a human actor holds an approved gate. Eq. (??)’s $complete(V, E)$ and $traceable(E, C, \Delta)$ conjuncts state the report contract’s structural guarantees—typed evidence links, provenance fields, and schema validation (Section ??)—enforced by the runtime rather than checked as separate temporal-logic predicates in this section.

At extended scope, autonomy held across 514–12,292 BFS states and Alloy remained UNSAT at $2 \times$ atom scope (6.3s); evidence mediation held across 13–275 states with exact TLC/Python agreement; and accountability held across 25–625 configurations with Alloy UNSAT at $3.3 \times / 2.5 \times$ scope. Violating controls produced counterexamples. Base scopes were 6 Time, 6 SystemState, 4 Actor, 2 Stage, 2 Component, 1 Gate2 and 6 Artifact, 4 Actor; witnesses *sanityChainIsNontrivial* and *sanityApprovalRecordsCanExist* guard against vacuity. Construct Validity states the full-scope semantic caveat.

The formal-to-operational mapping pairs each property with an executable check and mutation oracle. AI autonomy is enforced by schema rejection of authority fields, including injected *release_authorized*; human accountability by mandatory review routing, whose disabled default exposes an unreviewed report; and evidence mediation by missing-evidence denial plus SHACL checks, for which a weakened constraint fails. The trusted boundary comprises the schema, policy engine, curated facts, and external authorization service, assuming equivalent enforcement at external APIs, no bypass path, truthful inputs, and authenticated approvers. Factual completeness, human judgment, usability, identity, and production integration remain outside the prototype.

Negative controls expose vacuous invariants, disconnected states, reflexive steps, and short cycles; tests also detect mutations removing authority rejection, universal review, or technical-evidence constraints. The formal and executable checks therefore connect the advisory package to human review while authorization remains external.

VI. EVALUATION

We ask whether the architecture preserves the advice–authorization boundary (**RQ1**), what behavior appears in bounded-agent traces (**RQ2**), which defects OPA and SHACL detect separately and jointly (**RQ3**), and how enforcement changes routing, agreement, and review workload (**RQ4**). Formal analysis addresses RQ1 at the architectural level; the following experiments address all four questions operationally.

a) Claims and non-claims.: Absolute agreement rates in this section characterize the small open-weight generators under a strict conjunctive metric, not the architecture; the central claims concern boundary preservation and routing under enforcement, and none of the results below establishes clinical correctness or human reliance (Threats to Validity).

A. Setup

The primary benchmark contains 40 synthetic, non-patient arrhythmia bundles generated from a fixed template and governance rubric. It balances severity levels 1–4 and covers five recommendations, four evidence-completeness classes, four SNOMED CT concepts, and seven symbolic-check probes. A frozen 20/20 development/held-out split supports one unmodified held-out run. Eight paraphrases of each of five base scenarios form a separate 40-row stability check (Section ??).

A second frozen cohort contains 40 public MAUDE post-market reports, again split 20/20 [?]. Annotation retained source digests, explicit facts, and assertion status (*confirmed*, *suspected*, *negated*, or *mention-only*). Two team members independently labeled source narratives without access to generated reports or symbolic findings, followed by third-author adjudication. Development/held-out pre-adjudication Cohen’s κ was 0.72/1.00 for status, 0.90/0.74 for routing (quadratic-weighted), and 0.78/0.88 for evidence sufficiency. The released protocol, disagreements, and adjudication record make this internal governance reference reproducible.

No human participants or identifiable private information were involved (synthetic scenarios and public FDA MAUDE reports only); Institutional Review Board (IRB) approval and informed consent were therefore not required.

The *matched-strict* protocol fixes scenarios, retrieval, prompts, policy, curated facts, and generation settings across arms, varying only the model. Severity is ordinal (1–4); 95% Wilson CIs use development ($n = 20$), held-out ($n = 20$), or pooled ($n = 40$) scenarios, and recommendation accuracy is agreement with the governance reference. MAUDE, paraphrase, and cross-domain analyses retain the same fixed-scenario discipline with analysis-specific model rosters.

B. Boundary Enforcement (RQ1–RQ2)

1) Matched Bounded-Agent Campaign: The bounded planner’s action-contract enforcement—revalidating every model-proposed action against the legal transition set (Section ??)—is exercised end to end by the matched campaign, backed by a dedicated regression test and the full 86-test suite.

The model set contrasts Qwen3.5 and Gemma 3 across different tool-use priors. The 1B–27B range targets local open-weight deployment, relevant where governance restricts external processing of device artifacts. Across 2,000 runs, bounded-agent generation latency had a median of 14.3 s (range 7.4–72.8 s); policy latency was not instrumented separately. Pinned digests support traceability but did not eliminate serving or sampling variability.

The campaign covers ten models from three series (qwen2.5:7b; qwen3.5, 0.8B–27B; gemma3, 1B–27B) on both splits, comparing direct generation, RAG, bounded-agent output, and OPA-governed output under identical settings. Of 2,000 attempted agent runs, 1,947 yielded reports: 1,189 reached `advisory_complete`, 443 agent-proposed escalation, and 315 runtime-forced escalation after a refused second revision. The other 53 failed inside the report tool, all for qwen3.5:2b (70/100 development and 77/100 held-out completions) because pre-report text preceded valid JSON actions. Completion outcomes include all attempts; agreement rates condition on successful generation. Counting failures as non-agreement changes qwen3.5:2b development agreement from 10/70 (14.3%) to 10/100 (10.0%) for raw and agent+OPA; held-out agreement remains 0%. No terminated trace accepted a schema-invalid, unparseable, or state-illegal action.

Governance-exact-agreement jointly matches routing, evidence insufficiency, citation, and contradiction fields, and is therefore stricter than the single-field recommendation agreement reported in Sections ?? and ?. Table ?? gives exact counts. On development data, raw agent output exceeded the strongest non-agentic baseline for seven of nine fully completed models; OPA lowered agreement for five, left three unchanged, and raised qwen3.5:27b. On held-out data, agreement was nonzero for one raw agent versus six OPA-governed models because selected under-routes became reference-consistent escalations. Scenario-cluster-adjusted intervals remain wide, so comparisons are descriptive; qwen3.5:9b’s 13→8 change reflects severity-4 and evidence-completeness rules. qwen3.5:2b rates use 70/77 completed reports. Field decomposition and all intervals are in the reproducibility package.

2) Frozen Factorial Conformance Suite: An LLM-free suite tested OPA and SHACL against labeled violations. Its 48 prospective rows exposed three defects: substring matching of "confirmed" within "unconfirmed" and two malformed FHIR extensions accepted by SHACL. Exact-phrase and URL/valueCode allowlists repaired all three. The 54-row regression suite adds six technical-evidence cases and tests closure, not unseen-failure generalization. Eligible-row sensitivity rose from 87.5% to 12/12 for OPA and 16/16 for SHACL (95% Wilson lower bounds 75.8% and 80.6%); class coverage rose from 1/2 to 3/3 and 3/4 to 4/4.

TABLE I
RQ2/RQ4 MATCHED CAMPAIGN: COMPLETION AND GOVERNANCE-EXACT-AGREEMENT (AGREEMENT/COMPLETED OUTPUTS)

Model	Complete D/H		Development		Best base		Held-out	
			Raw	+OPA			+OPA	
qwen2.5:7b	100/100	15/100	25/100	25/100	0/100	0/100	10/100	
qwen3.5:0.8b	100/100	15/100	20/100	20/100	0/100	0/100	0/100	
gemma3:1b	100/100	15/100	14/100	14/100	0/100	0/100	0/100	
qwen3.5:2b [†]	70/77	10/100	10/70	10/70	0/100	0/77	0/77	
gemma3:4b	100/100	15/100	10/100	5/100	0/100	0/100	10/100	
qwen3.5:4b	100/100	15/100	25/100	20/100	0/100	0/100	5/100	
qwen3.5:9b	100/100	15/100	28/100	14/100	0/100	13/100	8/100	
gemma3:12b	100/100	15/100	30/100	25/100	0/100	0/100	9/100	
gemma3:27b	100/100	15/100	30/100	20/100	0/100	0/100	5/100	
qwen3.5:27b	100/100	15/100	25/100	30/100	0/100	0/100	0/100	

Best base is the stronger of direct generation and non-agentic RAG. [†]qwen3.5:2b denominators reflect completed agent reports; its non-agentic baselines completed 100 runs. qwen3.5:2b's completion numbers are reported at their original run status; a later same-digest reproducibility probe found drift for this model (Threats to Validity). Scenario-cluster-adjusted intervals for all cells are provided in the reproducibility package.

3) *Structural Boundary Evidence*: Operational results were consistent with the encoded boundary under the tested configurations: no accepted action was invalid or state-illegal in 2,000 runs, structural violations were 0/40 in the frozen benchmark, no paraphrase crossed the authority boundary, and cross-domain transfer produced no unsafe under-escalation. No tested input gave the agent authorization or execution capability.

C. Defect Detection (RQ3)

1) *Frozen Synthetic 40-Scenario Symbolic-Check Benchmark (OPA/SHACL Detection Decomposition)*: With mandatory review disabled, OPA-or-SHACL trigger yield measures the fraction of generated reports flagged by either check. Cross-tabulating OPA (on/off) against SHACL (on/off) over the same 40 scenarios gives a 2×2 decomposition of the two symbolic checks' detections: OPA-only, SHACL-only, overlap, and neither counts attribute each activation on the same generated report, while the structural boundary violation rate evaluates the report contract separately. This decomposes which check catches a defect on the same report; the pipeline is not re-executed with each check disabled, so ablated downstream agent behavior (revision, escalation) is not established.

Under the matched-strict protocol (Section ??), Table ?? reports the qwen2.5:3b results, retained as the single-series historical baseline for the two-series scaling sweep (Section ??). With routing disabled, union yield is 0.625 (0.350 development; 0.900 held-out).

Across qwen2.5:1.5b/3b/7b ($n = 40$ per arm), severity accuracy was 0.375/0.425/0.450, governed recommendation agreement was 0.375/0.425/0.425, and union yield was 0.825/0.625/0.900. SHACL-only catches increased from 4 to 6 to 12, showing incremental detection of severity under-calls after OPA had accepted the report's citation and procedural fields. These configurations provide the historical single-series baseline and field-provenance audit trail; the primary cross-series analysis appears in Section ??.

Distinct check capabilities are evaluated separately in the large language model (LLM)-free conformance suite against known defects (Section ??).

2) *Symbolic-Check Independence and Field-Sharing Effects*: We trace each active OPA rule and SHACL shape to its *RiskReport* field, classifying overlap as *structurally redundant*

TABLE II

FROZEN 40-SCENARIO BENCHMARK: MATCHED-STRICT QWEN2.5:3B RESULTS, POOLED (DEV.+HELD-OUT; UNION YIELD SPLIT NOTED IN TEXT). OPA-ONLY/SHACL-ONLY/OVERLAP/NEITHER ROWS FORM A 2×2 DETECTION DECOMPOSITION, NOT AN INDEPENDENTLY RE-EXECUTED ABLATION.

Metric (scenario-level)	Pooled ($n = 40$)
Severity accuracy	17/40=0.425 [0.285,0.578]
Policy-adjusted agreement with developer reference	17/40=0.425 [0.285,0.578]
Structural boundary violation rate [†]	0/40=0.000
OPA-or-SHACL union yield [‡]	25/40=0.625 [0.470,0.758]
OPA-only catches	16/40
SHACL-only catches	6/40
OPA/SHACL overlap (structural / genuine)**	3/40 (2/1)
Neither layer catches	15/40
Raw citation hallucination	5/40=0.125 [0.054,0.261]

[†]Structural gate outcome; no interval. [‡]Review gate disabled; union equals OPA-only + SHACL-only + overlap, with development/held-out yield 0.350/0.900. **Overlap is decomposed into shared-field and genuinely independent activation in Section ??.

Cluster-adjusted precision is discussed under Threats to Validity.

when both layers read the same field and condition, or *genuinely independent* otherwise.

The audit surfaces two confirmed field-sharing pairs. `report.evidence_links` emptiness drives both OPA's technical-evidence rule and SHACL's minimum-evidence shape, differing in coverage because OPA gates on severity ≥ 2 while SHACL is severity-blind. A severity-4 report without immediate escalation activates both the OPA forced-escalation rule and an explicitly corresponding SHACL shape. By contrast, SHACL's documented-outcome shape and OPA's high-severity rule read different sources (reference harm outcome versus predicted severity) and form a genuinely independent pair.

In the scaling sweep, field-sharing explains 87.5–92.5% of union findings at qwen3.5:4b and gemma3:27b and all their overlap (37/37 and 35/35). We therefore report *genuine incremental SHACL value*—SHACL-only plus non-structural overlap—with raw union yield. A CGM audit similarly identifies two literal duplicates.

3) *SHACL-Informed In-Loop Revision*: The bounded agent supports a SHACL-conditioned revision path: a nonconformance can activate the runtime's one-revision budget, injecting prior OPA actions and SHACL messages into the revision prompt. Under the same matched-strict protocol (Section ??), we applied it to qwen2.5:3b and one representative model from each additional series, qwen3.5:9b and gemma3:12b.

All 40 scenarios completed with real generation for all

TABLE III
SHACL-INFORMED IN-LOOP REVISION, CROSS-SERIES ($n = 40$
EACH; QWEN2.5:3B IS THE FROZEN SINGLE-SERIES BASELINE)

Model	Revise att.	SHACL-trig.	OPA-only	Chg. SHACL	Chg. OPA
qwen2.5:3b [†]	20/40	16/40	4/40	6/16 (37.5%)	0/4 (0.0%)
qwen3.5:9b	25/40	12/40	13/40	5/12 (41.7%)	3/13 (23.1%)
gemma3:12b	11/40	11/40	0/40	5/11 (45.5%)	—

[†]Frozen baseline, unchanged. gemma3:12b triggered no OPA-only revisions in this sample, so the OPA-only changed-rate is undefined (0/0). Cell sizes are 4–16 revisions; comparative efficacy is therefore treated descriptively.

three models, without fallback, schema/parsing failure, or illegal transition, at a median cost of 1,989 prompt and 437 completion tokens per call (120 calls, three models). Table ?? reports activation and content-change effectiveness. In the qwen2.5:3b baseline, 16 SHACL-triggered revisions changed severity or recommendation in 6 cases, while four OPA-only revisions produced no such change. One trace illustrates the full loop: SHACL detected missing evidence, revision added two regulatory links, and the final report cleared that violation.

SHACL-triggered revisions changed severity or recommendation in 5/12 qwen3.5:9b and 5/11 gemma3:12b cases, versus 6/16 at baseline. Final SHACL findings remained in 8/40, 19/40, and 34/40 reports, so content change did not imply full resolution. OPA actions fell from synthesis to revision (37→15, 67→48, and 118→41); per-scenario manifests document each change.

Content change does not by itself establish improvement, so a separate qwen2.5:3b run retained each scenario’s pre-revision and final reports and scored both against fixed developer-authored reference labels established before report generation. Among the 20/40 scenarios where revision was attempted, exact agreement rose from 5/20 (25%) to 9/20 (45%): five scenarios moved from incorrect to correct, one moved from correct to incorrect, four stayed correct, and ten stayed incorrect. The observed shift is a modest descriptive net improvement (+4 scenarios; exact McNemar $p = 0.219$), not evidence that most revised reports were corrected.

D. Governance Trade-off (RQ4)

1) *Public MAUDE Routing Benchmark*: On the held-out MAUDE subset with qwen2.5:3b as the default generation model, OPA reduced under-routing to zero (0.10, 95% Wilson [0.028,0.301], to 0.00, [0.000,0.161]) while over-routing rose to 0.70 (95% Wilson [0.481,0.855]); the full development/hold-out breakdown, including the pre-governance baseline, is in Table ?. The result directly exposes the policy’s intended asymmetry: fewer under-routed reports in exchange for additional human review. Paired exact McNemar tests on the 20 held-out cases confirm this asymmetry’s statistical character: the over-routing increase is significant (6 discordant cases, all in the conservative direction, $p = 0.031$), while the under-routing change rests on only 2 discordant cases and does not reach significance ($p = 0.5$)—the under-routing estimate remains imprecise because only two discordant cases were observed, consistent with the effective-sample-size discussion in Threats to Validity.

Across six representative qwen3.5 (2B/4B/27B) and gemma3 (1B/12B/27B) configurations, governed under-

TABLE IV
MAUDE ELECTROCARDIOGRAM (ECG) COHORT: AGREEMENT WITH
GOVERNANCE LABELS (20 + 20 REPORTS)

Metric	Development	Held-out
Pre-governance routing agreement	0.35	0.50
Governed routing agreement [§]	0.35	0.30
Pre-governance under-routing	0.30	0.10
Governed under-routing	0.10	0.00
Governed over-routing	0.55	0.70
Evidence-insufficiency agreement	0.45	0.30

[§]95% Wilson intervals: development 7/20 [0.181, 0.567]; held-out 6/20 [0.145, 0.519]. The held-out set was not used to modify prompt, policy, or mapping.

routing is 0.0–0.25 and over-routing 0.45–0.90. Over-routing rises at all 14 development/hold-out points; under-routing falls at 13, with one tie (gemma3:1b development, 0.25). Full routing curves are in the reproducibility package.

In this small held-out set, six additional over-routes accompanied two corrected under-routes, an observed 3:1 review-load trade-off. Whether this burden causes alert fatigue or degraded attention requires human evaluation [?]. Because routing derives from declarative Rego rules rather than model behavior, the operating point is a policy calibration rather than an architectural constant: severity thresholds, evidence-completeness tiers, or reviewer-load-aware queues could trade review volume against under-routing risk without modifying the agent, report contract, or authorization boundary. Calibration against measured reviewer capacity remains future work.

2) *Model-Scale Sensitivity of Symbolic Checks*: We tested whether the Qwen2.5 pattern persists across nine qwen3.5 (0.8B–27B) and gemma3 (1B–27B) configurations under the matched-strict protocol; eight met the prespecified completion criterion.

Union yield is nonmonotonic: it reaches 1.000 at qwen3.5:4b and gemma3:27b, with 87.5–92.5% structurally shared findings, but falls to 0.125 at qwen3.5:27b. That model still achieves 0.650 severity accuracy (1.000 within one level) without citation hallucinations or retries. Thirteen of its 14 errors are over-calls outside the one-sided `concept_severity_undercall` rule; the sole under-call fires it, and no case has empty `evidence_links`. Provenance therefore identifies both detected defects and coverage gaps.

3) *Cross-Domain Stress Test*: A CGM/insulin-dosing stress test reuses the DAG and report contract with a new policy and curated layer ($n = 20$; qwen2.5:3b; three unseeded repeats). No scenario was unsafely under-escalated (95% Wilson [0.000,0.161]); human review was 20/20, severity accuracy 10/20, and recommendation agreement changed from 12/20 before OPA to 10/20 after OPA. Mean Artifact Recall@4 was 0.65, row-macro citation validity 0.9736, and scenario-level validity 19/20. Across 18 runs, severity accuracy ranged from 0.15 to 0.85, Artifact Recall@4 from 0.55 to 0.65, and macro citation validity from 0.91 to 1.00. Assertion-status handling remained the main transfer weakness, while deterministic enforcement separated boundary consistency from model accuracy.

4) *Paraphrase Robustness*: Eight paraphrases of five curated scenarios provide a correlated 40-row stability check. With qwen2.5:3b, governed recommendation agreement was 24/40, OPA-or-SHACL union yield was 19/40 (3 OPA-only,

6 SHACL-only, 10 overlap), all runtime checks passed, and no report crossed the authority boundary. qwen3.5:4b and gemma3:27b reproduced the shared-field pattern (37/37 and 34/34 overlap cases), whereas qwen3.5:27b showed no structural overlap; qwen3.5:0.8B and 2B did not complete because of repeated schema-validation failures.

VII. CASE STUDY AND DISCUSSION

A post-market arrhythmia drift alert becomes a typed signal linked to the affected model. The agent retrieves artifacts and records gaps in a cited *RiskReport*; OPA routes it, SHACL checks curated facts, and field provenance identifies complementary findings (Section ??). The stable contract permits generator changes without redefining governance, while production can protect the external gate through policy-as-code controls [?], [?].

Human Decision Rights

Human-centered operation requires reviewer control of release and access to sources, gaps, confidence, and policy actions. Reviewers can disagree, request evidence, or return a high-risk recommendation that omits required subgroup evidence without treating advice as authorization. Linking each decision to its audit trace also supports future studies of calibrated reliance [?], [?], [?].

Threats to Validity

Internal validity: scenario similarity creates dependence. Token-Jaccard analysis connected 36 scenarios into 19 clusters; a 1.7–2.0 design effect reduced the effective sample to roughly 20–23 and widened the pooled severity-accuracy interval from [0.285, 0.578] to [0.238, 0.636]. The frozen split and unpinned-seed repeats measure post-freeze behavior and output variance, not additional independent scenarios.

External validity: eight of nine scaling configurations completed; MAUDE, CGM, and paraphrase analyses use subsets, and qwen3.5:0.8B/2B failed the longer paraphrase protocol. The study targets local 1B–27B open-weight models and curated or protocol-derived data, not proprietary models or multi-site deployments; the 0/20 CGM unsafe count retains a 16.11% upper bound.

Construct validity: developer-authored labels test execution of a loaded governance specification, not clinical authority. MAUDE evaluates OPA but not full SHACL; shared-team annotation and repaired-case reuse may favor the rules. The analyses establish selected architectural properties, not reliance or clinical correctness. Alloy restricts Time to one total order, matching Python BFS and TLA+/TLC; the earlier multi-chain encoding was UNSAT only at partial extended scope. The reformulation aligns the three methods rather than weakening the property, and guarantees remain limited to single-execution-history semantics. Resource profiling beyond generation latency, live integration, authenticated authorization, and production SHACL remain untested. Section ??’s decomposition isolates which check catches a defect on one report, not agent-vs-fixed-workflow or independently re-executed OPA/SHACL; both remain future work.

Model reproducibility: a same-digest re-probe 72 hours after the original run varied by configuration. qwen3.5:2b (original union yield 0.725) exhausted retries on one split and increased failures on the other (4/40 versus 1/40), a reliability regression without evident outcome changes among completed cases. qwen3.5:9b changed 1/40 governed outcomes and its genuine SHACL rate from 0.125 to 0.200; gemma3:27b retained union yield 1.000 with 0/40 disagreements. Because revision re-invokes the model, claims are bounded to same-digest, same-day conditions. The CGM severity spread (0.20, 0.55, 0.50) likewise exposes sampling variance.

a) *Data and code availability:* The package at [ZENODO DOI] contains benchmarks, annotations, models, policies, traces, and scripts that regenerate results from hashed raw outputs under the qualification above.

VIII. CONCLUSION

The architecture assigns recommendation and authorization to different objects, actors, and controls. Its *RiskReport* connects a bounded agent to OPA, SHACL, and a modeled external human gate. Within the checked bounds, formal analysis found no counterexample under single-execution-history semantics. Of 2,000 attempted runs, 1,947 terminated under control (1,189 packages; 758 escalations), with no state-illegal action accepted. The evaluations exposed complementary detection and the workload cost of conservative routing—a trade-off that lives in declarative policy and can be recalibrated without touching the agent, contract, or authority boundary. The interface keeps evidence assembly inspectable and distinct from release authority; external independent annotation, human evaluation, and authenticated integration remain future work.

ACKNOWLEDGMENT

The authors used OpenAI Codex for language editing, LaTeX formatting, and plotting code. They reviewed and validated all outputs and take full responsibility for the manuscript.

CONFLICT OF INTEREST

The authors declare no conflicts of interest.

- [1] K. Lekadir et al., “FUTURE-AI: International consensus guideline for trustworthy and deployable artificial intelligence in healthcare,” *BMJ*, vol. 388, Art. no. e081554, Feb. 2025, doi: 10.1136/bmj-2024-081554.
- [2] E. Tabassi, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1, National Institute of Standards and Technology, Gaithersburg, MD, USA, Jan. 2023, doi: 10.6028/NIST.AI.100-1.
- [3] European Parliament and Council, “Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence,” *Official Journal of the European Union*, L 2024/1689, Jul. 12, 2024. [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>
- [4] U.S. Food and Drug Administration, “Artificial intelligence/machine learning (AI/ML)-based software as a medical device (SaMD) action plan,” Jan. 2021. [Online]. Available: <https://www.fda.gov/medical-devices/software-medical-device-samd/artificial-intelligencemachine-learning-aiml-based-software-medical-device-samd-action-plan>.

- [5] U.S. Food and Drug Administration, "Marketing submission recommendations for a predetermined change control plan for artificial intelligence-enabled device software functions," Final Guidance for Industry and FDA Staff, Dec. 2024. [Online]. Available: <https://www.fda.gov/regulatory-information/search-fda-guidance-documents/marketing-submission-recommendations-predetermined-change-control-plan-artificial-intelligence>.
- [6] European Parliament and Council, "Regulation (EU) 2017/745 on medical devices," *Official Journal of the European Union*, L 117, pp. 1–175, May 5, 2017.
- [7] G. Kondylakis et al., "A review of methods for trustworthy AI in medical imaging: The FUTURE-AI guidelines," *IEEE J. Biomed. Health Inform.*, vol. 30, no. 3, pp. 2299–2315, Mar. 2026, doi: 10.1109/JBHI.2025.3614546.
- [8] *Medical Devices—Quality Management Systems—Requirements for Regulatory Purposes*, ISO 13485:2016, International Organization for Standardization, Geneva, Switzerland, 2016.
- [9] *Medical Devices—Application of Risk Management to Medical Devices*, ISO 14971:2019, International Organization for Standardization, Geneva, Switzerland, 2019.
- [10] *Information Technology—Artificial Intelligence—Management System*, ISO/IEC 42001:2023, International Organization for Standardization/International Electrotechnical Commission, Geneva, Switzerland, 2023.
- [11] U.S. Food and Drug Administration, Health Canada, and U.K. Medicines and Healthcare products Regulatory Agency, "Good machine learning practice for medical device development: Guiding principles," Oct. 2021. [Online]. Available: <https://www.fda.gov/media/153486/download>.
- [12] National Institute of Standards and Technology, *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, NIST AI 600-1, Gaithersburg, MD, USA, Jul. 2024, doi: 10.6028/NIST.AI.600-1.
- [13] B. Vasey et al., "Reporting guideline for the early-stage clinical evaluation of decision support systems driven by artificial intelligence: DECIDE-AI," *Nature Med.*, vol. 28, no. 5, pp. 924–933, May 2022, doi: 10.1038/s41591-022-01772-9.
- [14] N. J. Economou-Zavlanos et al., "Translating ethical and quality principles for the effective, safe and fair development, deployment and use of artificial intelligence technologies in healthcare," *J. Amer. Med. Inform. Assoc.*, vol. 31, no. 3, pp. 705–713, Mar. 2024, doi: 10.1093/jamia/ocad221.
- [15] A. Wang, S. Freeman, and F. Magrabi, "Governance for safe and responsible AI in healthcare organisations: A scoping review of frameworks," *npj Digit. Med.*, vol. 9, Art. no. 516, May 2026, doi: 10.1038/s41746-026-02679-2.
- [16] H. Toivakka, T. Granlund, T. Poranen, and Z. Zhang, "Towards RegOps: A DevOps pipeline for medical device software," in *Product-Focused Software Process Improvement*, LNCS 13126, Cham, Switzerland: Springer, 2021, pp. 290–306, doi: 10.1007/978-3-030-91452-3_20.
- [17] F. O. Mirto, "PhD Forum: BioDevOps: Toward a formal framework for continuous deployment in safety-critical medical devices," in *Proc. 2026 IEEE Int. Conf. Smart Computing Workshops and Other Affiliated Events (SmartComp Companion)*, 2026, pp. 424–426, doi: 10.1109/SmartComp-Companion70724.2026.00094.
- [18] P. Lewis et al., "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Advances in Neural Information Processing Systems 33*, 2020, pp. 9459–9474.
- [19] S. Yao et al., "ReAct: Synergizing reasoning and acting in language models," in *Proc. 11th Int. Conf. Learn. Representations*, Kigali, Rwanda, May 2023.
- [20] S. Vatsal, H. Dubey, and A. Singh, "Agentic AI in healthcare and medicine: A seven-dimensional taxonomy for empirical evaluation of LLM-based agents," arXiv preprint arXiv:2602.04813, Feb. 2026.
- [21] S. Schmidgall et al., "AgentClinic: A multimodal agent benchmark to evaluate AI in simulated clinical environments," arXiv preprint arXiv:2405.07960, May 2024.
- [22] Y. Jiang et al., "MedAgentBench: A realistic virtual EHR environment to benchmark medical LLM agents," arXiv preprint arXiv:2501.14654, Jan. 2025.
- [23] G. Aránguiz Dias et al., "The doctor will (still) see you now: On the structural limits of agentic AI in healthcare," arXiv preprint arXiv:2602.18460, Feb. 2026.
- [24] W. Li et al., "Refine medical diagnosis using generation augmented retrieval and clinical practice guidelines," *IEEE J. Biomed. Health Inform.*, early access, Dec. 2025, doi: 10.1109/JBHI.2025.3641931.
- [25] K. Yu et al., "Benchmarking foundation models with multimodal public electronic health records," *IEEE J. Biomed. Health Inform.*, early access, Dec. 2025, doi: 10.1109/JBHI.2025.3645076.
- [26] K. Goddard, A. Roudsari, and J. C. Wyatt, "Automation bias: A systematic review of frequency, effect mediators, and mitigators," *J. Amer. Med. Inform. Assoc.*, vol. 19, no. 1, pp. 121–127, Jan. 2012, doi: 10.1136/amiajnl-2011-000089.
- [27] S. Gaube et al., "Do as AI say: Susceptibility in deployment of clinical decision-aids," *npj Digit. Med.*, vol. 4, Art. no. 31, Feb. 2021, doi: 10.1038/s41746-021-00385-9.
- [28] P. Tschandl et al., "Human-computer collaboration for skin cancer recognition," *Nature Med.*, vol. 26, no. 8, pp. 1229–1234, Aug. 2020, doi: 10.1038/s41591-020-0942-0.
- [29] D. Liu et al., "SNOMED CT-powered knowledge graphs for structured clinical data and diagnostic reasoning," arXiv preprint arXiv:2510.16899, Oct. 2025.
- [30] HL7 International, "FHIR Release 4: Fast Healthcare Interoperability Resources." [Online]. Available: <https://hl7.org/fhir/R4/>.
- [31] SNOMED International, "SNOMED CT Starter Guide." [Online]. Available: <https://confluence.ihtsdotools.org/display/DOCSTART>.
- [32] World Wide Web Consortium, "Shapes Constraint Language (SHACL)," W3C Recommendation, Jul. 20, 2017. [Online]. Available: <https://www.w3.org/TR/shacl/>.
- [33] World Wide Web Consortium, "OWL 2 Web Ontology Language document overview," W3C Recommendation, Dec. 11, 2012. [Online]. Available: <https://www.w3.org/TR/owl2-overview/>.
- [34] M. Leucker and C. Schallhart, "A brief account of runtime verification," *J. Log. Algebr. Program.*, vol. 78, no. 5, pp. 293–303, May–Jun. 2009, doi: 10.1016/j.jlap.2008.08.004.
- [35] Open Policy Agent, "Policy-based control for cloud native environments." [Online]. Available: <https://www.openpolicyagent.org/>.
- [36] GitHub Docs, "Managing environments for deployment." [Online]. Available: <https://docs.github.com/actions/deployment/targeting-different-environments/managing-environments-for-deployment>.
- [37] T. Rebedea, R. Dinu, M. N. Sreedhar, C. Parisien, and J. Cohen, "NeMo Guardrails: A toolkit for controllable and safe LLM applications with programmable rails," in *Proc. 2023 Conf. Empirical Methods Natural Language Processing: System Demonstrations*, Singapore, Dec. 2023, pp. 431–445, doi: 10.18653/v1/2023.emnlp-demo.40.
- [38] H. Wang, C. M. Poskitt, and J. Sun, "AgentSpec: Customizable runtime enforcement for safe and reliable LLM agents," in *Proc. 48th IEEE/ACM Int. Conf. Softw. Eng. (ICSE)*, Rio de Janeiro, Brazil, Apr. 12–18, 2026, 12 pp., doi: 10.1145/3744916.3764546.
- [39] *Medical Device Software—Software Life Cycle Processes*, IEC 62304:2006+AMD1:2015, International Electrotechnical Commission, Geneva, Switzerland, 2015.
- [40] U.S. Food and Drug Administration, "Manufacturer and User Facility Device Experience (MAUDE) Database." [Online]. Available: <https://www.accessdata.fda.gov/scripts/cdrh/cfdocs/cfm/maude/search.cfm>.